

ISO/IEC 27001:2022 LEAD IMPLEMENTER PORTFOLIO

Information Security Management System — End-to-End Implementation

A Practical Case Study Of

AWTX Solutions Pty Ltd
Melbourne, Victoria — Australia

Simulated case-study organisation based on a realistic Australian SME operating structure

PREPARED BY
Zain Younas
Lead Implementer

DOCUMENT REF
ZY-PORT-001
Version 1.0

DATE OF ISSUE
November 2025
Melbourne, AU

Declaration of Authorship

I, Zain Younas, declare that this portfolio document has been prepared independently as a demonstration of my competence as an ISO/IEC 27001:2022 Lead Implementer. The artefacts referenced in this report, including the ISMS Scope Document, Risk Register, Risk Treatment Plan, Statement of Applicability, Internal Audit programme, Corrective Action Register, and Management Review Minutes, were produced by me using a structured methodology aligned with ISO/IEC 27001:2022 and ISO/IEC 27005:2022 risk-management guidance.

All references and external sources have been acknowledged using the Harvard referencing style. AWTX Solutions Pty Ltd is a simulated case-study organisation created solely for portfolio demonstration purposes and based on a realistic Australian SME operating structure; any resemblance to a real entity is unintended. All names, dates, and signatures throughout the artefacts are case-study placeholders.

SIGNED

Zain Younas — Lead Implementer, ISO/IEC 27001:2022 — November 2025

Abstract

Note on the case study — AWTX Solutions Pty Ltd is a simulated case-study organisation created solely for this portfolio. All names, contracts, audit findings, dates, and signatures are illustrative. The methodology, ISO/IEC 27001:2022 clause and Annex A mapping, and the Australian regulatory context (Privacy Act 1988, ASD Essential Eight) reflect a realistic Lead Implementer engagement.

This portfolio documents the planning, design, and implementation of an Information Security Management System (ISMS) for AWTX Solutions Pty Ltd, a Melbourne-based small-to-medium enterprise developing cloud-hosted SaaS products, including an Event Booking and Management Platform. The engagement was triggered by an enterprise client due diligence review that exposed significant governance gaps and required ISO/IEC 27001:2022 certification as a precondition for contract renewal.

Acting as Lead Implementer, I followed a Plan–Do–Check–Act methodology to define the ISMS scope, assess ISO/IEC 27001:2022 clauses and Annex A control requirements, conduct a qualitative 3 × 3 information-security risk assessment producing eighteen registered risks, design a corresponding risk treatment plan, build a Statement of Applicability covering all 93 Annex A controls, run a first-cycle internal audit yielding 13 Major non-conformities, 13 Minor non-conformities, and 8 observations, and prepare the inaugural Management Review for senior management approval.

The deliverables presented here evidence the practical application of ISO/IEC 27001:2022 Clauses 4–10 and Annex A, alignment with the ASD Essential Eight maturity model, and adherence to the Privacy Act 1988 (Cth). The work is presented as a structured case study to demonstrate my capability to lead an end-to-end ISMS implementation from foundation through certification readiness; dates and milestones reflect the planning horizon adopted at the time of the engagement and are retained here for academic and professional-portfolio purposes.

Table of Contents

PART 1	Case Study — AWTX Solutions Pty Ltd	
1.1	Organisation Profile	5
1.2	The Trigger Event	6
1.3	Identified Gaps & Drivers	6
1.4	The Mandate	7
PART 2	Lead Implementer Portfolio	
2.1	Introduction & Implementer Role	8
2.2	Methodology — Plan–Do–Check–Act	8
2.3	Scenario 1 — Defining the ISMS Scope	9
2.4	Scenario 2 — Information-Security Risk Assessment	10
2.5	Scenario 3 — Risk Treatment Plan	11
2.6	Scenario 4 — Statement of Applicability	12
2.7	Scenario 5 — Internal Audit	13
2.8	Scenario 6 — Non-Conformance & Corrective Actions	14
2.9	Scenario 7 — Management Review	15
PART 3	Risk Register Workbook — Tab-by-Tab Walkthrough (5 W's)	
3.1	Tab 1 — Risk Methodology	18
3.2	Tab 2 — Risk Assessment	19
3.3	Tab 3 — Risk Treatment	20
3.4	Tab 4 — Statement of Applicability	21
3.5	Tab 5 — Risk Summary	22
3.6	Tab 6 — ISMS Implementation Roadmap	23
3.7	Tab 7 — Internal Audit(IA) Programme & Schedule	24
3.8	Tab 8 — Internal Audit(IA) Checklist & Findings	25
3.9	Tab 9 — Internal Audit(IA) Summary & Sign-Off	26
3.10	Tab 10 — Corrective Action Register	27
3.11	Tab 11 — Management Review Minutes	28
PART 4	Demonstrated Competencies, Conclusion & References	
4.1	Demonstrated Competencies Matrix	30
4.2	Conclusion	30

4.3 References

31

PART 1

Case Study — AWTX Solutions Pty Ltd

1.1 Organisation Profile

AWTX Solutions Pty Ltd is a Melbourne-based small-to-medium enterprise specialising in custom software development, cloud-hosted business applications, eCommerce platforms, and enterprise web solutions. Headquartered in South Yarra, Victoria, the company employs approximately thirty people across software development, project management, cloud engineering, support, sales, and senior management.

AWTX primarily delivers custom SaaS solutions for Australian businesses and government-related clients. Its flagship product is an Event Booking and Management Platform used by multiple clients across Australia for ticketing, event registration, attendee management, payment processing, and customer communication.

Snapshot — At a Glance

30 Employees	1 Flagship Platform	2 Cloud Providers	10+ Enterprise Clients
------------------------	-------------------------------	-----------------------------	----------------------------------

Information Assets in Scope

Asset Category	Description	CIA Impact
Customer Data	Customer PII — names, addresses, phones, emails	C, I
Financial Data	Payment transaction records, invoices, billing data	C, I
Legal & Contractual	Event-organiser contracts, supplier agreements	C
HR & Personnel	Internal HR records, employee payroll information	C, I
Cloud Infrastructure	AWS/Azure credentials & administrative access records	C, I, A
Source Code & IP	Repositories, CI/CD pipelines, custom SaaS platform code	C, I

Cloud & Operational Posture

- Amazon Web Services (AWS) — production hosting, databases, backups, IAM, application services.
- Microsoft Azure — identity management (Azure AD), Microsoft 365, endpoint security, disaster-recovery support.
- Third-party payment gateways — customer transaction integrations and PCI-relevant flows.
- Agile delivery and remote-working culture — staff access systems from the Melbourne office and remote locations.

1.2 The Trigger Event

In 2025, during a major client security due-diligence review, several concerns were raised by an enterprise customer before contract renewal. The client requested formal evidence of information-security governance and identified material weaknesses across the AWTX environment. The renewal of a strategically important contract was placed on hold pending demonstrable improvement, and the customer ultimately conditioned future renewal on AWTX achieving ISO/IEC 27001:2022 certification.

1.3 Identified Gaps & Drivers

Governance Gaps Identified by the Client

#	Identified Gap	Severity
1	No formal Information Security Management System	Major
2	Missing risk register and risk treatment process	Major
3	No approved Statement of Applicability	Major
4	Weak access-control review process	Major
5	Lack of formal supplier security assessments	Major
6	Incomplete incident-response procedures	Major
7	Insufficient backup-restoration testing evidence	Major
8	No structured internal-audit process	Major
9	Limited security-awareness training records	Minor
10	Absence of formal ISO/IEC 27001 certification	Major

Strategic Drivers Beyond the Client

- Government tender security requirements — alignment with sector procurement standards.
- Cyber-insurance obligations — insurers requiring evidence of mature controls.
- Increasing ransomware threats — sector-wide incident frequency is rising.
- Compliance expectations from enterprise customers — beyond the initial trigger client.
- Board-level concern regarding cyber resilience and brand exposure.
- Alignment requirements with the ASD Essential Eight maturity model.

1.4 The Mandate

Due to the commercial risk of losing major clients and the need to improve governance maturity, senior management approved a strategic project to implement a full ISO/IEC 27001:2022-compliant ISMS and achieve certification within twelve months.

The author was appointed as the ISO/IEC 27001 Lead Implementer and Cyber Security Governance Specialist responsible for leading the complete ISMS implementation project from initial gap assessment through to certification readiness and external audit preparation.

Scope of the Lead Implementer Mandate

ESTABLISH	Define and approve the ISMS framework and governance
ASSESS	Conduct information-security risk assessments across all in-scope assets
DEFINE	Establish and document the ISMS scope and boundaries (Cl. 4.3)
BUILD	Produce the Statement of Applicability covering all 93 Annex A controls
IMPLEMENT	Operationalise selected Annex A controls in collaboration with technical teams
AUDIT	Plan and execute first-cycle internal audits (Cl. 9.2)
REVIEW	Coordinate management reviews and corrective-action tracking (Cl. 9.3, 10)
CERTIFY	Prepare the organisation for Stage 1 and Stage 2 certification audits

OBJECTIVE	Ensure AWTX Solutions Pty Ltd achieves successful ISO/IEC 27001:2022 certification while strengthening operational security, customer trust, regulatory compliance, and long-term business growth.
------------------	--

PART 2

Lead Implementer Portfolio

2.1 Introduction & Implementer Role

Document Purpose

This portfolio has been prepared to demonstrate the practical capability of the author as a Lead Implementer for ISO/IEC 27001:2022. It presents a structured walkthrough of an end-to-end Information Security Management System implementation undertaken for AWTX Solutions.

Responsibilities

ISO Reference	Responsibility
Cl. 4.3	Define and obtain approval for the ISMS scope
Cl. 6.1.2	Design and apply the information-security risk-assessment methodology
Cl. 6.1.3	Produce the Risk Register, Risk Treatment Plan, and Statement of Applicability
Annex A	Implement operational and technical controls in collaboration with technical teams
Cl. 9.2	Plan and execute the first-cycle internal audit
Cl. 9.3 / 10	Record non-conformities, track corrective actions, and prepare inputs for Management Review
External	Prepare the organisation for Stage 1 and Stage 2 external certification audits

2.2 Methodology — Plan–Do–Check–Act

The implementation followed the Plan–Do–Check–Act (PDCA) cycle promoted by ISO management-system standards (Calder, 2018), aligned with the structured guidance for risk management in ISO/IEC 27005:2022. The project lifecycle was decomposed into six discrete phases, each producing planned or in-progress ISMS artefacts used to support internal audit, management review, corrective-action tracking, and external certification preparation. Where artefacts remained draft or pending approval, their approval status and required actions were tracked through the roadmap, corrective-action register, and Management Review outputs.

PDCA Mapping to AWTX Implementation Phases

PDCA	Phase	Activities	Timeline
PLAN	Phase 1–2	Foundation, Governance, Risk Assessment & Treatment	Jul–Sep 2025
DO	Phase 3	Control Implementation across all 18 risk treatment items	Sep–Nov 2025
CHECK	Phase 4	Internal Audit, NCR recording, corrective-action planning, and first Management Review	Oct–Nov 2025
ACT	Phase 5–6	Certification preparation, Stage 1 document review, Stage 2 implementation verification, and closure of open Major NCRs before Stage 2	Dec 2025 – Mar 2026
STANDARDS APPLIED	ISO/IEC 27001:2022 • ISO/IEC 27005:2022 • ASD Essential Eight Maturity Model • Privacy Act 1988 (Cth)		

2.3 Scenario 1 — Defining the ISMS Scope

CLAUSE 4.3 Determining the boundaries and applicability of the ISMS to establish its scope.

Scenario

ISO/IEC 27001:2022 Clause 4.3 requires the organisation to determine the boundaries and applicability of its ISMS. AWTX management requested that the scope be sufficiently comprehensive to satisfy enterprise customers' due-diligence expectations, while remaining realistic for an organisation of approximately thirty employees. The Lead Implementer engaged with department heads, reviewed contractual obligations, and analysed cloud-shared-responsibility arrangements with AWS and Microsoft Azure to define organisational, physical, and technical boundaries.

Output — ISMS Scope Document (AWTX-SCOPE-001)

The output of this activity is the formal ISMS Scope Document, which articulates the in-scope organisational areas, locations, technologies, information assets, business processes, exclusions, and interested parties.

Boundary Type	Scope
Organisational	All AWTX departments — Dev, Cloud, IT, HR, Finance, Sales, Senior Management
Physical	South Yarra (VIC) office; all authorised remote-work locations
Technical	Event Booking & Management Platform; AWS production; Azure identity & M365
Information	Customer PII; payment data; HR records; source code; cloud credentials
Suppliers	Material processors of in-scope information (AWS, Azure, payment gateways)
Exclusions	Physical security of AWS/Azure data centres (justified under shared-responsibility model)

Explanation

The ISMS scope explicitly includes the Event Booking and Management Platform together with its supporting cloud infrastructure on AWS and Azure, the South Yarra office, all authorised remote-work locations, and the third-party suppliers that materially process in-scope information. Exclusions, such as the physical security of AWS and Azure data centres, are recorded with documented justification under the shared-responsibility model. Documenting exclusions transparently is critical: it demonstrates risk-based reasoning to certification auditors and prevents the scope ambiguity that frequently leads to audit non-conformities.

2.4 Scenario 2 — Information-Security Risk Assessment

CLAUSE 6.1.2

Define and apply a documented information-security risk-assessment process.

Scenario

Clause 6.1.2 requires the organisation to define and apply a documented risk-assessment process. AWTX had no formal risk register prior to the engagement. The Lead Implementer designed a 3 × 3 qualitative risk-rating matrix in which Consequence and Likelihood are each scored on a 1–3 scale, producing a Risk Score (C × L) ranging from 1 to 9. Risks are then categorised as Low (1–2), Medium (3–4), High (5–6), or Critical (7–9). The methodology was applied within the Risk Methodology tab of the workbook and is intended to be formalised as AWTX-RM-001, a standalone version-controlled methodology document. The approach is consistent with ISO/IEC 27005:2022 risk-management guidance.

Output — Risk Register

A workshop-driven asset inventory and threat-modelling exercise produced eighteen registered risks affecting in-scope information assets.

Risk Distribution at Initial Assessment



Sample Risks — Critical Tier

Risk ID	Information Asset	Threat	Score	Rating
RA-001	Event Booking Platform	Ransomware / malware attack	9	Critical
RA-002	Production AWS Environment	Unauthorised admin-console access	9	Critical
RA-006	Cloud Credentials (AWS/Azure)	Credential theft or exposure	9	Critical

Explanation

Each risk was decomposed into asset, threat, vulnerability, existing controls, CIA impact, and a mapped reference to ISO/IEC 27001:2022 Annex A. For example, RA-001 captures the ransomware threat against the Event Booking Platform, which scored 3 × 3 = 9 (Critical) due to incomplete patching processes and the absence of EDR on all devices. Mapping each risk to specific Annex A controls (e.g., A.8.7 Anti-malware, A.5.16 Identity Management) ensures that the subsequent Statement of Applicability is risk-driven rather than checklist-driven.

2.5 Scenario 3 — Risk Treatment Plan

CLAUSE 6.1.3

Determine and apply risk-treatment options and select the necessary Annex A controls.

Scenario

Clause 6.1.3 requires the organisation to determine and apply risk-treatment options and to select the necessary Annex A controls. For each registered risk, the Lead Implementer evaluated four treatment options, which are Modify, Transfer, Avoid, Accept and selected appropriate Annex A controls. Pre-treatment and target (planned) residual risk values were recorded for each risk to define the expected effect of the proposed controls; actual effectiveness will be evidenced once the controls are implemented and verified.

Aggregate Risk Reduction — Pre-Treatment vs Target (Planned) Residual

Risk Rating	Pre-Treatment	Target Residual	Δ Change	Direction
Critical (7–9)	3	0	–3	↓ reduced
High (5–6)	10	0	–10	↓ reduced
Medium (3–4)	3	11	+8	↑ increased
Low (1–2)	2	7	+5	↑ increased

Explanation

The treatment plan demonstrates the principle that risk reduction is achieved primarily by lowering likelihood through preventive controls (e.g., MFA enforcement, EDR deployment, secrets management). Consequence often remains unchanged because the inherent sensitivity of the data asset cannot be reduced without business-process redesign. Residual-risk justifications were recorded for all 18 risks. The treatment plan shows a target residual profile of 0 Critical, 0 High, 11 Medium, and 7 Low risks, provided the selected controls are fully implemented. As of the October 2025 review point, 16 of 18 treatment actions remained Not Started and 2 were In Progress; therefore, senior management review and resource approval were required before claiming Stage 2 readiness.

2.6 Scenario 4 — Statement of Applicability

CLAUSE 6.1.3(c)

Produce a Statement of Applicability covering all 93 Annex A controls of ISO/IEC 27001:2022.

Scenario

Clause 6.1.3(c) requires the organisation to produce a Statement of Applicability (SoA) that lists all 93 Annex A controls of ISO/IEC 27001:2022 (organised under four themes: Organisational, People, Physical, Technological), records the applicability decision, justifies inclusion or exclusion, and captures implementation status. The SoA is the central reference document used during external certification audits.

SoA Headline Numbers



New 2022 Controls Specifically Assessed in the AWTX SoA

- A.5.7 — Threat Intelligence
- A.5.23 — Information Security for Cloud Services
- A.5.30 — ICT Readiness for Business Continuity
- A.7.4 — Physical Security Monitoring
- A.8.9 — Configuration Management
- A.8.10 — Information Deletion
- A.8.11 — Data Masking
- A.8.12 — Data Leakage Prevention
- A.8.16 — Monitoring Activities
- A.8.23 — Web Filtering
- A.6.7 — Remote Working

Explanation

Each control entry captures applicability, inclusion or exclusion justification, implementation status, control owner, linked risk identifiers, evidence reference, and target completion date. The SoA is the artefact certification auditors examine first; an SoA that is internally consistent with the Risk Register, the Risk Treatment Plan, and operational evidence is a strong indicator of ISMS maturity. The 2022 revision of the standard reduced Annex A from 114 to 93 controls and introduced eleven new controls, each individually assessed in the AWTX SoA.

2.7 Scenario 5 — Internal Audit

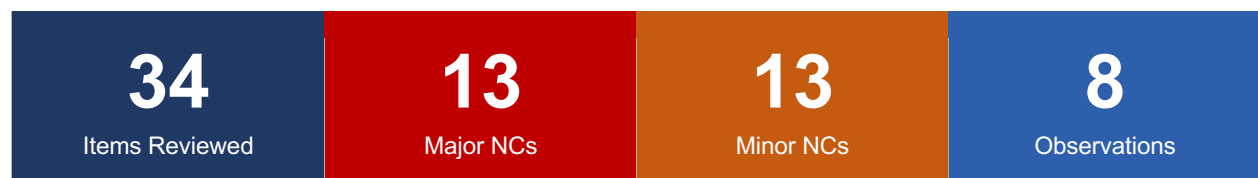
CLAUSE 9.2

Conduct internal audits at planned intervals to determine ISMS conformity and effectiveness.

Scenario

Clause 9.2 requires the organisation to conduct internal audits at planned intervals to determine whether the ISMS conforms to the standard and is effectively implemented and maintained. The Lead Implementer prepared a three-part internal audit programme covering (i) Audit Programme & Schedule, (ii) Checklist & Findings Register, and (iii) Summary & Sign-Off, collectively referenced as AWTX-IA-001. Cl. 9.2 independence requires that auditors be independent of the activities they audit; the Lead Implementer therefore did not self-audit work they themselves designed. An external Audit Advisor was engaged to provide independent review of the audit programme, sample the execution evidence, and confirm finding classifications, and the Audit Advisor's independence declaration is retained on the audit file.

Internal Audit Headline Findings



Audit Phases

Phase	Coverage	Date
Phase 1	Cl. 4–6 — Context & Leadership	Aug 2025
Phase 2	Cl. 7–8 — Support & Operations	Sep 2025
Phase 3	Annex A Controls (Org/People/Physical/Tech)	Sep–Oct 2025
Phase 4	Cl. 9–10 — Performance & Improvement	Oct 2025

Explanation

The high volume of Major non-conformities is consistent with a first-cycle internal audit conducted during the implementation phase, before all controls reach steady-state operation. Major findings centred on the absence of a formally approved Information Security Policy, the lack of a formal security-awareness programme, and incomplete operational controls (notably MFA enforcement, incident response, and backup-restoration testing). All 13 Major non-conformities and 13 Minor non-conformities are tracked in the Corrective Action Register (AWTX-NCR-001). The 8 observations are tracked separately in the same register as improvement opportunities. Within the case-study plan, all Major NCs were required to be closed before the Stage 2 certification audit, while Minor NCs required agreed corrective actions and evidence-based tracking to closure.

2.8 Scenario 6 — Non-Conformance & Corrective Actions

CLAUSE 10.2

React to non-conformities, eliminate causes, implement actions, and review effectiveness.

Scenario

Clause 10.2 requires the organisation to react to non-conformities, evaluate the need to eliminate their causes, implement actions, and review effectiveness. The Lead Implementer maintained a Corrective Action Register that captured every audit finding, identified the root cause, defined the corrective action, assigned ownership, and recorded verification evidence.

Sample NCR — Worked Example: Access Control and MFA Enforcement Gap

Audit Reference	IA-026
Clause / Annex A	A.5.15–A.5.18 • A.8.2 • A.8.5
Finding Type	Major Non-Conformity
Finding	MFA not enforced on all AWS IAM and Azure AD accounts. No Access Control Policy approved. No quarterly access review conducted.
Root Cause	MFA partially configured but not enforced as policy. No ownership of access-review process.
Corrective Action	Enforce MFA on all AWS, Azure, M365 accounts. Approve Access Control Policy. Conduct and document quarterly access review. Establish review schedule.
Owner	CTO / Cloud Engineer
Target Date	2025-09-30

Explanation

The register records a structured root-cause analysis for each finding. NCR-006 relates to MFA enforcement gaps across AWS IAM, Azure AD, and Microsoft 365, and was traced to the absence of an approved Access Control Policy, incomplete enforcement of authentication controls, and the lack of a formal quarterly access-review schedule. The corrective action, therefore, extended beyond the technical fix (enforcing MFA) to include policy approval, ownership assignment, and quarterly access-review scheduling. This addresses both the symptom and the systemic cause, as required by Clause 10.2(b).

2.9 Scenario 7 — Management Review

CLAUSE 9.3

Top management reviews the ISMS at planned intervals to ensure suitability, adequacy, and effectiveness.

Scenario

Clause 9.3 of ISO/IEC 27001:2022 requires top management to review the ISMS at planned intervals to ensure its continuing suitability, adequacy, and effectiveness. The Lead Implementer convened the inaugural Management Review in November 2025 (AWTX-MRM-001), with the CEO chairing and the senior management team in attendance, hybrid-delivered from the South Yarra office and Microsoft Teams.

Mandatory Inputs (Cl. 9.3.2) Addressed

- Status of previous Management Review actions — first-cycle baseline established.
- ISMS objectives status — ISO/IEC 27001:2022 certification by Q1 2026, staff training, MFA enforcement, and Incident Response Plan completion.
- Internal-audit results — 13 Major NCs, 13 Minor NCs, 8 observations, and 0 conforming items.
- Risk-assessment and treatment status — 18 risks identified; 3 Critical, 10 High, 3 Medium, and 2 Low before treatment.
- Risk-treatment progress — 16 of 18 treatment actions Not Started and 2 In Progress as of October 2025.
- Interested-party feedback — 10 enterprise-client due-diligence weaknesses formally acknowledged and tracked.
- Risk-treatment adequacy — all 18 risks assigned the Modify treatment option, with a target residual profile of 0 Critical, 0 High, 11 Medium, and 7 Low risks.
- Opportunities for improvement — ISMS KPI dashboard, monthly risk-treatment review meetings, communications planning, and continual-improvement tracking.
- Policy and scope review — Information Security Policy and ISMS Scope Document requiring formal CEO sign-off.
- Resource adequacy — EDR, MDM, vulnerability scanning, secrets management, and implementation effort requiring management approval.
- Regulatory and compliance status — Privacy Act 1988, Privacy Impact Assessment, Privacy Policy, ASD Essential Eight alignment, and cyber-insurance obligations.
- Certification timeline — Stage 1 audit targeted for February 2026 and Stage 2 audit targeted for March 2026, subject to closure of critical open actions.

Documented Outputs (Cl. 9.3.3)

Action Ref	Decision / Action	Owner
MRM-ACT-001	CEO to formally sign Information Security Policy and ISMS Scope Document.	CEO
MRM-ACT-002	Management to formally accept the Risk Assessment and approve the Risk Treatment Register with risk-owner sign-off.	ISMS Manager / Risk Owners
MRM-ACT-003	Approve ISMS Resource Plan including budget for EDR, MDM, and vulnerability scanning tooling.	CEO / CTO
MRM-ACT-004	Establish monthly Risk Treatment Review Meeting cadence, with the first meeting by end November 2025.	ISMS Manager
MRM-ACT-005	CTO to provide weekly status updates on RA-001, RA-002, and RA-006 until closed.	CTO
MRM-ACT-006	ISMS Manager to develop Privacy Policy and initiate Privacy Impact Assessment for the Event Booking Platform.	ISMS Manager

MRM-ACT-007	HR Manager to initiate Security Awareness Training Programme delivery to all 30 staff. Original October 2025 target overdue at the time of this Management Review; revised target is end of December 2025 with weekly status to ISMS Manager.	HR Manager / ISMS Manager
MRM-ACT-008	ISMS Manager to finalise and publish ISMS Objectives Register with SMART metrics and KPI dashboard.	ISMS Manager
MRM-ACT-009	CEO to present ISMS status to the board at the next board meeting, with the ISMS Manager to prepare the board briefing pack.	CEO
MRM-ACT-010	ISMS Manager to schedule Stage 1 readiness dry run for January 2026 and engage the certification body.	ISMS Manager / CEO

Explanation

The Management Review agenda was structured to address the required ISO/IEC 27001:2022 Clause 9.3.2 inputs, including previous-review actions, ISMS objectives, internal-audit results, risk-assessment and treatment status, interested-party feedback, resource adequacy, regulatory obligations, and opportunities for continual improvement. The review did not claim full Stage 2 readiness; instead, it formally recorded management decisions required to move toward certification readiness, including approval of the Risk Assessment and Risk Treatment Register, CEO sign-off of key ISMS documents, resource approval for priority tooling, weekly tracking of Critical risks RA-001, RA-002, and RA-006, and a Stage 1 readiness dry run scheduled for January 2026.

PART 3

Risk Register Workbook — Tab-by-Tab Walkthrough (5 W's)

READER GUIDE

Each section below explains one tab of the AWTX Risk Register workbook (AWTX-RA-001) using the 5 W's method — Who, What, Where, When, Why — followed by the key decisions made and the rationale for each decision.

Workbook Reference

Document Reference	AWTX-RA-001 / AWTX-RT-001 / AWTX-SOA-001 / AWTX-IA-001 / AWTX-NCR-001 / AWTX-MRM-001
Standard	ISO/IEC 27001:2022 with ISO/IEC 27005:2022 risk-management guidance
Period Covered	Risk-Assessment Period 2025–2026
Total Tabs	11 — Risk Methodology, Risk Assessment, Risk Treatment, Statement of Applicability, Risk Summary, ISMS Implementation Roadmap, IA Programme & Schedule, IA Checklist & Findings, IA Summary & Sign-Off, Corrective Action Register, Management Review Minutes
Owner	ISMS Lead Implementer / Cyber Security Governance Specialist

3.1 Tab 1 — Risk Methodology

DOC REF	AWTX-RM-001 • ISO/IEC 27001:2022 Cl. 6.1.2 — methodology
WHO	Authored by the ISMS Lead Implementer as the embedded risk methodology used within the workbook. Formal standalone approval of AWTX-RM-001 is tracked as an open improvement action, because the internal audit identified that the methodology was applied consistently but had not yet been issued as a separate, version-controlled document. Risk Owners and Asset Owners apply it operationally; the external Audit Advisor independently reviewed its consistent use.
WHAT	The embedded risk-management rulebook used within the workbook, to be formalised into a standalone, version-controlled AWTX-RM-001 document. It defines risk acceptance criteria, the 1–3 Consequence scale, the 1–3 Likelihood scale, the 3 × 3 scoring matrix, the four treatment options, and the roles and responsibilities matrix for risk activities.
WHERE	The reference document underneath every other risk-related tab. Tab 2 (Risk Assessment) and Tab 3 (Risk Treatment) cannot be defended without this tab.
WHEN	Methodology applied from July 2025 within the workbook; standalone AWTX-RM-001 to be finalised, version-controlled, and formally approved as part of the open corrective-action and Management Review actions. Review frequency is annual each July and out-of-cycle following significant change.
WHY	ISO/IEC 27001:2022 Cl. 6.1.2(a) requires the risk-assessment process itself to be documented. Without a methodology document the entire risk register is one auditor's question away from being thrown out.

Risk Acceptance Criteria

Rating	Acceptance Decision	Timeframe	Escalation
Critical (7–9)	NOT ACCEPTED — immediate treatment	Within 30 days	CEO & CTO
High (5–6)	NOT ACCEPTED — treatment plan required	Within 3 months	ISMS Manager
Medium (3–4)	Conditionally accepted with treatment	Within 6 months	ISMS Manager (aware)
Low (1–2)	Accepted — monitor and review	Annual review	No escalation

Key Decisions Made

Decision	Reason
Tie acceptance decisions to a defined timeframe and escalation level	Eliminates the common audit finding of 'risk acceptance criteria stated but not operationalised'. Each rating now has a date and a name attached.
Limit scoring to a 1–3 scale, not 1–5	Ensures the team can score reliably without false precision. Smaller scales are more consistently applied across the 30-person organisation.
Document Modify as the default option, with Avoid noted as not applied	Pre-empt the auditor's question 'why was Avoid never used?'. Avoid was considered, for example, for RA-005 (source code access) by ceasing remote contractor access; this was rejected because remote contractor work is core to AWTX's SaaS delivery model and removing it would not be commercially viable. The methodology records this reasoning so the auditor sees the test was applied, not skipped.
Define an explicit Roles & Responsibilities matrix for risk	Resolves the 'who does what' ambiguity that derails risk programmes once the Lead Implementer leaves.

Tie the methodology directly to the SoA control selection logic

Closes the chain — methodology drives assessment, assessment drives treatment, treatment drives SoA. Auditors love a clean chain of evidence.

3.2 Tab 2 — Risk Assessment

DOC REF

AWTX-RA-001 • ISO/IEC 27001:2022 Cl. 6.1.2

WHO	Owned by the ISMS Lead Implementer, with active input from each Asset Owner (CTO, Cloud Engineer, HR Manager, Finance Manager, Software Dev Lead, Head of Customer Support, Head of Procurement). Risk Owners are documented per row.
WHAT	A line-by-line register of 18 information-security risks. Each row captures asset, owner, threat, vulnerability, Consequence (1–3), Likelihood (1–3), Risk Score (C × L), Risk Rating, existing controls, CIA impact, ISO 27001 Annex A reference, and treatment-required flag.
WHERE	This tab is the foundational evidence artefact for Cl. 6.1.2 and feeds every downstream tab: Risk Treatment, SoA, Internal Audit, and Management Review.
WHEN	Risks were captured during workshops in July–August 2025 and are reviewed annually plus on every significant change (new system, new client, post-incident).
WHY	AWTX had no formal risk register before the engagement, a Major gap raised by the trigger client. Without this register the SoA cannot be defended and certification is impossible.

Key Decisions Made

Decision	Reason
Adopt 3 × 3 qualitative matrix	Right-sized for a 30-person SME, achievable, defensible, and consistent with ISO/IEC 27005:2022. A 5 × 5 matrix would have introduced false precision without improving treatment outcomes.
Score Consequence and Likelihood independently	Lets the team see whether risk reduction comes from lowering likelihood (controls) or consequence (data minimisation). Treatment plans are then targeted, not generic.
Map every risk to specific Annex A controls	Forces the SoA to be risk-driven, not checklist-driven. Eliminates the common audit finding of 'controls without justification'.
Document existing controls, not just gaps	Auditors look for evidence of what already works. This builds credibility and avoids over-stating risk.
Land at exactly 18 risks (not 100+)	A small, sharply defined register is reviewed and acted upon. Bloated registers become shelf-ware.

3.3 Tab 3 — Risk Treatment

DOC REF AWTX-RT-001 • ISO/IEC 27001:2022 Cl. 6.1.3

WHO	Authored by the ISMS Lead Implementer. Each treatment row requires Risk Owner sign-off, with senior-management approval required for any residual risk above appetite.
WHAT	For every risk in Tab 2, this tab records the chosen treatment option (Modify / Transfer / Avoid / Accept), the selected Annex A controls, the action required, the residual-risk justification, target residual Consequence/Likelihood/Score, owner, target completion date, implementation status, and evidence required.
WHERE	Sits between the Risk Assessment (Tab 2) and the Statement of Applicability (Tab 4). It is the operational bridge from 'we know we have a risk' to 'we have a defensible plan to treat it'.
WHEN	Treatment plans were authored August–September 2025; target completion dates run from August 2025 through November 2025 to align with the Stage 2 audit window in Q1 2026.
WHY	Cl. 6.1.3 obliges the organisation to demonstrate not only that risks are identified but that they are being actively treated. Without this tab the Risk Register is a description of problems with no solution.

Key Decisions Made

Decision	Reason
Apply 'Modify' to all 18 risks	Every in-scope activity is essential to the business, Avoid was not viable. The risks are core security risks that no insurer or third party will fully accept on AWTX's behalf.
Capture pre-treatment and target residual scores	Quantifies the value of each control and lets management see whether the spend is justified. Critical evidence at Management Review.
Link controls back to specific Annex A IDs	Maintains traceability, auditor can walk from any control on a server back to a board-approved decision.
Force a residual-risk justification narrative on every row	Stops the cosmetic 'reduce likelihood from 3 to 1 because controls' answer. Each line has to argue why the control actually works.
Treat consequence as largely fixed	The sensitivity of customer PII or payment data cannot be reduced without business-process change. Treatment focuses on lowering likelihood, this is honest and defensible.
Define explicit evidence required per row	Closes the loop, auditors will ask 'show me'. Each treatment line names the artefact (e.g., AWS GuardDuty config, MFA report, restoration test record).

3.4 Tab 4 — Statement of Applicability

DOC REF AWTX-SOA-001 • ISO/IEC 27001:2022 Cl. 6.1.3(c)

WHO	Authored by the ISMS Lead Implementer; control-by-control entries are signed off by the named Control Owner; the document as a whole is submitted for CEO/senior-management approval.
WHAT	A row per Annex A control (93 in total) capturing: Control Reference, Name, Description, Category, Applicable (Y/N), Inclusion/Exclusion Justification, Implementation Status, Linked Risks from the Risk Register, Control Owner, Evidence Reference, CIA Impact, Priority, and Target Date.
WHERE	The single document the certification body opens first. It is the spine of the entire ISMS every audit conversation eventually returns to a row in the SoA.
WHEN	First version (v1.0) was prepared in July 2025 and reviewed continuously through the implementation period. Formal CEO/senior-management approval is tracked through the implementation roadmap and Management Review actions, with the next formal review scheduled for July 2026.
WHY	Cl. 6.1.3(c) is non-negotiable. Auditors use the SoA to drive sampling, a coherent SoA is the difference between a passed audit and a failed one. It is also the primary evidence document for enterprise client due diligence.

SoA Coverage

93 Total Controls	93 Applicable	0 Excluded	4 Themes
-----------------------------	-------------------------	----------------------	--------------------

Key Decisions Made

Decision	Reason
Mark every Annex A control Applicable, including A.7.12 (Cabling Security)	AWTX is cloud-first, but the South Yarra office is in scope and physical cabling does carry information. Marking A.7.12 Applicable — Low priority, with the operating control inherited from the building's facilities provider — is more defensible at audit than a blanket exclusion. A nil-exclusion SoA also pre-empts the common "why was this excluded?" line of questioning.
Link every applicable control to one or more risks (RA-IDs)	Demonstrates risk-driven control selection, the gold-standard interpretation of Cl. 6.1.3. A control with no risk linkage either belongs out of scope or signals an unidentified risk.
Capture both Implementation Status and Target Date	Lets auditors see the trajectory, not just the snapshot. 'In Progress' with a credible target date is acceptable; 'Not Started' with no date is not.
Name a Control Owner for every applicable control	Forces accountability. A control without an owner is a control without an operator and therefore not really implemented.
Use the four 2022 themes (Org / People / Physical / Tech)	Matches the 2022 revision exactly. Makes audit sampling and gap mapping faster for both AWTX and the certification body.
Highlight the 11 new 2022 controls explicitly	Demonstrates that AWTX understood the transition from the 2013 standard directly addresses a frequent BSI transition-audit question.

3.5 Tab 5 — Risk Summary

DOC REF AWTX-RM-001 (summary view) • Management Reporting Artefact

WHO	Compiled by the ISMS Lead Implementer; consumed by the CEO, CTO, ISMS Manager, and the Management Review meeting.
WHAT	A dashboard tab summarising counts and percentages per risk rating both pre-treatment and target residual, plus a Top-Risks panel listing every Critical risk and its target close date. The tab is the visual executive summary of the Risk Assessment and Risk Treatment tabs, showing the movement from the pre-treatment risk profile to the planned target residual-risk profile.
WHERE	First slide of any board or Management Review pack. It is the answer to the executive question 'how risky are we, and is it getting better?'.
WHEN	Refreshed monthly by the ISMS Manager during the implementation phase, then quarterly thereafter. Always re-cut before each Management Review.
WHY	Senior management cannot read 18 detailed risk rows in a 60-minute meeting. Without this tab the risk programme has no airtime at the top table and a programme without executive airtime quietly dies.

Pre-Treatment vs Target (Planned) Residual Risk Profile

Rating	Pre-Treatment	Target Residual
Critical (7–9)	3	0
High (5–6)	10	0
Medium (3–4)	3	11
Low (1–2)	2	7

Key Decisions Made

Decision	Reason
Show pre-treatment and target residual side by side	Tells the story in one glance — the planned residual profile reduces all Critical and High risks to Medium or Low once treatments are fully implemented. Anything more complex loses executive attention.
Carve out a 'Top Risks Requiring Immediate Treatment' panel	Forces explicit accountability on the three Critical risks (RA-001, RA-002, RA-006). Senior management cannot un-see them once listed by name.
Use percentages alongside counts	On 18 risks the percentages are clean (17%, 56%, etc.) and translate well to slides without distorting the underlying numbers.
Refresh monthly during implementation, quarterly after	Matches the cadence of the Risk Treatment Review Meeting and avoids 'dashboard fatigue' once the programme stabilises.

3.6 Tab 6 — ISMS Implementation Roadmap

DOC REF	AWTX-ROAD-001 • Project & Programme Artefact
WHO	The ISMS Lead Implementer plans and tracks; named roles (CEO, CTO, Cloud Engineer, HR Manager, IT Manager, Software Dev Lead, ISMS Manager, Head of Procurement) execute against assigned deliverables.
WHAT	A 40-row task register decomposed across six phases (Foundation & Governance → Risk Assessment → Control Implementation → Internal Audit → Certification Prep → Stage 2 Audit). Each row records the deliverable, ISO clause / Annex A reference, phase, priority, target date, responsible role, status, % complete, and required evidence/output.
WHERE	The single source of truth for 'what's left and who owns it' across the entire ISO 27001 programme. Sits alongside the Risk Treatment Plan but covers the wider ISMS, not just risk-driven controls.
WHEN	Period July 2025 – March 2026, with phase boundaries hard-coded so slippage is visible. Stage 1 audit Feb 2026, Stage 2 audit Mar 2026.
WHY	ISO 27001 implementations fail more often from poor project management than from poor security. The roadmap converts the standard's clauses into 40 deliverables with owners, dates, and evidence — turning intent into execution.

Six-Phase Structure

Phase 1	Foundation & Governance	Jul–Aug 2025
Phase 2	Risk Assessment & Treatment	Aug–Sep 2025
Phase 3	Control Implementation	Sep–Nov 2025
Phase 4	Internal Audit & Review	Oct–Nov 2025
Phase 5	Certification Preparation	Dec 2025 – Jan 2026
Phase 6	Stage 2 Certification Audit	Feb–Mar 2026

Key Decisions Made

Decision	Reason
Six phases instead of a continuous backlog	Phase boundaries make milestone-based reporting natural and let executives see slippage early. A flat backlog hides slip until it is fatal.
Tie every deliverable to an ISO clause / Annex A reference	Forces every task to be standard-justified. No 'nice-to-have' tasks survive the first review.
Front-load Critical risk treatments (Phase 3, RD-015 onwards)	MFA, EDR, secrets management, IRP and backup testing close the highest-impact risks first and produce the strongest evidence for Management Review and Stage 1.
Lock Stage 2 to Q1 2026	A hard date drives behaviour. Open-ended certification programmes drift indefinitely; date-driven ones do not.
Track % complete on every row	Lets the ISMS Manager produce a credible status update without re-running interviews each month.

3.7 Tab 7 — Internal Audit(IA) Programme & Schedule

DOC REF AWTX-IA-001 (Part 1) • ISO/IEC 27001:2022 Cl. 9.2

WHO	The Lead Implementer prepared the audit programme, scope, criteria, and schedule. To address the Cl. 9.2 independence requirement — which the Lead Implementer cannot satisfy alone in respect of work they themselves designed — independent review support was provided by an external Audit Advisor, who reviewed the audit plan and sampled the execution evidence.
WHAT	The programme tab establishes the audit's purpose, scope, criteria, audit team, auditees, certification basis, and schedule — broken into four phases covering ISO/IEC 27001:2022 Clauses 4–10 and Annex A controls, with detailed checklist sampling focused on the highest-priority Annex A controls linked to AWTX's critical and high risks.
WHERE	Sits ahead of Tab 8 (Findings) as the planning artefact. Without this tab the audit is undocumented activity rather than a controlled Cl. 9.2 process.
WHEN	Audit period July–October 2025. Next review July 2026 on an annual cycle, plus a pre-surveillance audit in April 2026.
WHY	Cl. 9.2 mandates that internal audits be conducted at planned intervals, with criteria, scope, and methods defined in advance. Auditing without a programme is itself a Major non-conformity — the absence of this tab is a finding.

Audit Phase Structure

Phase	Coverage	Date
Phase 1	Cl. 4 (Context), 5 (Leadership), 6 (Planning)	Aug 2025
Phase 2	Cl. 7 (Support), 8 (Operation)	Sep 2025
Phase 3	Annex A — Org / People / Physical / Tech	Sep–Oct 2025
Phase 4	Cl. 9 (Performance), 10 (Improvement)	Oct 2025

Key Decisions Made

Decision	Reason
Sequence audits along the standard's clause order	Mirrors how the certification body will audit at Stage 1 and Stage 2 — internal audit becomes a faithful dry run.
Use an external advisor for independent review	The Lead Implementer cannot independently audit work they themselves designed. Engaging an external advisor to review the programme and sample execution closes that Cl. 9.2 independence gap and strengthens audit credibility.
Set the next-review date now, not later	Locks in the annual audit obligation and avoids the common Cl. 9.2 finding where the second-cycle audit slips and creates a gap.
Document audit team, auditees, and certification basis up front	Removes scope ambiguity once the audit starts and means findings cannot be argued as 'out of scope'.

3.8 Tab 8 — Internal Audit(IA) Checklist & Findings

DOC REF	AWTX-IA-001 (Part 2) • ISO/IEC 27001:2022 Cl. 9.2 — execution
WHO	The Lead Implementer prepared the checklist and recorded findings during fieldwork; the ISMS Manager reviewed the evidence and the external Audit Advisor independently sampled the execution to satisfy Cl. 9.2 independence. Auditees are the relevant department heads (CTO, Cloud Engineer, HR Manager, Software Dev Lead, IT Manager, Finance, Procurement, Customer Support, Senior Management).
WHAT	A 34-item checklist covering each ISO clause and the highest-priority Annex A controls. Each row records: audit reference, area/clause, audit objective, evidence required, audit question, auditor, audit date, finding, finding type (Major NC / Minor NC / Observation / Conforming), corrective action, target date, responsibility, status, and evidence reference.
WHERE	The execution heart of the audit programme. Tab 7 plans, this tab records, Tab 9 totals.
WHEN	Audited progressively across August–October 2025 by phase. Each finding is dated to anchor it in the audit timeline.
WHY	ISO/IEC 27001:2022 Cl. 9.2.2 demands documented evidence of the audit programme implementation and of the audit results. A planned audit without a recorded execution is a paper exercise the certification body will reject.

Findings Distribution

13 Major NC	13 Minor NC	8 Observations	0 Fully Conforming
-----------------------	-----------------------	--------------------------	------------------------------

Key Decisions Made

Decision	Reason
Pose a specific audit question per row, not a tick-box	Forces evidence-based assessment. Auditors must say 'show me the IAM MFA report', not 'is MFA in place?'.
Capture the corrective action inside the same row as the finding	Eliminates the lag between finding and remediation. The corrective action is born in the same artefact as the finding.
Classify findings as Major / Minor / Observation / Conforming	Mirrors BSI's audit-grading vocabulary. Trains the AWTX team in the language they will encounter at Stage 2.
Cross-reference findings to RA-IDs in the Risk Register	Closes the loop between audit and risk. A finding tied to RA-009 instantly tells the CEO why it matters.
Accept zero 'fully conforming' results in the first cycle	An honest first audit always finds something. Recording zero conforming items signals rigour, not incompetence and the certification body reads it that way.

3.9 Tab 9 — Internal Audit(IA) Summary & Sign-Off

DOC REF	AWTX-IA-001 (Part 3) • ISO/IEC 27001:2022 Cl. 9.2.2
WHO	Lead Auditor (ISMS Lead Implementer) prepares the audit summary for closure; the ISMS Manager / CISO reviews the results; CEO approval is captured through the sign-off block once the audit summary is formally accepted.
WHAT	An aggregate dashboard of the 34 audit items (Major / Minor / Observation / Conforming counts) plus a sign-off block recording lead-auditor signature, ISMS-manager review, CEO approval, audit completion date, and the next audit date.
WHERE	Closes the audit cycle. Without this tab the audit is open-ended and the certification body cannot draw on its conclusions.
WHEN	Prepared after completion of Tab 8 in October 2025, with formal review, sign-off, and approval captured in the audit sign-off block. Triggers the next-audit booking (April 2026 pre-surveillance). The signature lines in the workbook are retained as case-study placeholders.
WHY	Cl. 9.2.2 requires audit reports be retained as documented information and reported to relevant management. The sign-off is the artefact that demonstrates that requirement has been met.

Key Decisions Made

Decision	Reason
Aggregate by finding type rather than by clause	Management cares about counts and trends; clause-by-clause detail belongs in Tab 8. The summary serves a different audience.
Bind the next-audit date into the sign-off	Prevents the second-cycle audit from drifting and turns the annual cadence into a contractual artefact rather than a memo.
Use a colour legend matching BSI's published guidance	Aligns AWTX language with the certification body's vocabulary; reduces translation overhead at Stage 2.
Require both ISMS Manager review AND CEO approval	Two-line accountability operational sign-off and executive sign-off. Mirrors the leadership commitment required by Cl. 5.1.

3.10 Tab 10 — Corrective Action Register

DOC REF AWTX-NCR-001 • ISO/IEC 27001:2022 Cl. 10.2

WHO	Owned by the ISMS Manager / CISO. Each NCR has a named responsible role (CTO, CEO, HR Manager, Cloud Engineer, Head of Procurement, etc.) and the Lead Implementer tracks closure.
WHAT	All 34 internal-audit outcomes from Tab 8 are tracked in this register. The register contains 26 NCR records, made up of 13 Major NCs and 13 Minor NCs, plus 8 Observation records tracked as improvement opportunities. Each row captures the source audit reference, ISO clause or Annex A reference, finding type, finding description, root cause where applicable, corrective action required, target date, responsible owner, status, closure date, and evidence of closure. Some findings are intentionally recorded against both an ISO clause and a related Annex A control (e.g., NCR-001 / NCR-025 for Cl. 5.2 and A.5.1 / A.5.2; NCR-004 / NCR-026 for Cl. 7.3 and A.6.3) to evidence dual conformance — cross-references are deliberate, not duplicates.
WHERE	Sits between the Internal Audit (Tab 8) and the next Management Review (Tab 11). It is the operational artefact that turns findings into closed actions.
WHEN	Created October 2025 immediately after the first-cycle internal audit. Within the case-study timeline, all 13 Major NCs were required to be closed before the planned Stage 2 certification audit in March 2026.
WHY	Cl. 10.2 requires the organisation to react to non-conformities, identify causes, implement actions, and verify effectiveness. Without this register the audit is performative — findings are recorded but never resolved, and certification fails.

Corrective Action Register Mix

34 Total Records	13 Major NC	13 Minor NC	8 Observations
---------------------	----------------	----------------	-------------------

Key Decisions Made

Decision	Reason
Record a structured root-cause analysis on every Major NC	Clause 10.2(b) requires elimination of the cause, not the symptom. A structured root-cause analysis is recorded for every Major NC to enforce that depth on the rows that matter most.
Track observations in the same corrective-action register, but identify them separately as OBS records	This avoids losing improvement opportunities while still keeping a clean distinction between formal NCRs and observations. Major and Minor NCs remain corrective-action records, while observations are managed as improvement actions for the next audit cycle.
Require evidence-of-closure on every row	A closed NCR with no evidence is not closed it is forgotten. Auditors will sample for evidence; the register pre-empts that.
Cross-reference NCR rows back to specific Annex A controls	Closes the loop with the SoA. The auditor can pivot from any control to its NCR history with a single lookup.
Group by finding type at the top of the register	Lets management see at a glance which findings could block certification (Major NCs), which can run on (Minor NCs), and which are improvement opportunities (Observations).

3.11 Tab 11 — Management Review Minutes

DOC REF	AWTX-MRM-001 • ISO/IEC 27001:2022 Cl. 9.3
WHO	Chaired by the CEO. Mandatory attendees: CTO, ISMS Manager, Cloud Engineer, HR Manager, IT Manager, Finance Manager, Head of Procurement. Minuted by the Lead Implementer.
WHAT	Formal minutes of the inaugural ISMS Management Review. Captures every input required by Cl. 9.3.2 (status of previous actions, internal/external issues, IS performance, audit results, interested-party feedback, risk-assessment results, opportunities for improvement) and every output required by Cl. 9.3.3 (decisions on continual improvement, ISMS changes, and resource needs).
WHERE	The closing artefact of the first PDCA cycle — and the opening artefact of the next. Inputs flow from Tabs 2, 3, 5, 8, 9, 10; outputs become entries in Tab 6 and Tab 10.
WHEN	Held November 2025 (hybrid — South Yarra office and Microsoft Teams). Next review scheduled April 2026 to support the pre-surveillance audit cycle. Attendee names (e.g., [CEO Name]) and signature lines in the workbook are retained as case-study placeholders.
WHY	Cl. 9.3 mandates top-management review. Without these minutes there is no evidence that leadership owns the ISMS — and the certification body will treat that absence as a Major non-conformity directly against Cl. 5.1 and 9.3 simultaneously.

Mandatory Inputs Reviewed (Cl. 9.3.2)

- Status of previous Management Review actions — first-cycle baseline established.
- ISMS objectives status — ISO/IEC 27001:2022 certification by Q1 2026, staff training, MFA enforcement, and Incident Response Plan completion.
- Internal-audit results — 13 Major NCs, 13 Minor NCs, 8 observations, and 0 conforming items.
- Risk-assessment and treatment status — 18 risks identified; 3 Critical, 10 High, 3 Medium, and 2 Low before treatment.
- Risk-treatment progress — 16 of 18 treatment actions Not Started and 2 In Progress as of October 2025.
- Interested-party feedback — 10 enterprise-client due-diligence weaknesses formally acknowledged and tracked.
- Risk-treatment adequacy — all 18 risks assigned the Modify treatment option, with a target residual profile of 0 Critical, 0 High, 11 Medium, and 7 Low risks.
- Opportunities for improvement — ISMS KPI dashboard, monthly risk-treatment review meetings, communications planning, and continual-improvement tracking.
- Policy and scope review — Information Security Policy and ISMS Scope Document requiring formal CEO sign-off.
- Resource adequacy — EDR, MDM, vulnerability scanning, secrets management, and implementation effort requiring management approval.
- Regulatory and compliance status — Privacy Act 1988, Privacy Impact Assessment, Privacy Policy, ASD Essential Eight alignment, and cyber-insurance obligations.
- Certification timeline — Stage 1 audit targeted for February 2026 and Stage 2 audit targeted for March 2026, subject to closure of critical open actions.

Key Decisions Made

Decision	Reason
Structure the agenda exactly to Cl. 9.3.2	Removes the certification body's most common Cl. 9.3 finding — 'inputs not all addressed'. The agenda doubles as the audit checklist.
Capture decisions as MRM-ACT references with owner & date	Turns every output of the meeting into a tracked action. No one leaves the room with an ambiguous commitment.
Schedule the next MRM at the close of this one	Locks in the cadence. Cl. 9.3 requires planned intervals so the next interval is now planned, not aspirational.
Require CEO chair, not delegation	Cl. 5.1 leadership commitment is hard to evidence by exception. The CEO in the chair is the cleanest evidence the auditor will ever see.
Run hybrid (office + Teams) and minute both modes	Reflects how AWTX actually operates and avoids the optical 'all-leaders-on-site' performance that does not match the remote-first reality.

PART 4

Demonstrated Competencies, Conclusion & References

4.1 Demonstrated Competencies Matrix

Competency Area	ISO Reference	Evidence in this Portfolio
ISMS Scope Definition	Cl. 4.3	Part 2 §2.3
Leadership & Policy	Cl. 5.1, 5.2	Part 3 §3.10 NCR-001, NCR-003
Risk Assessment	Cl. 6.1.2	Part 2 §2.4 • Part 3 §3.2
Risk Treatment & SoA	Cl. 6.1.3	Part 2 §2.5–2.6 • Part 3 §3.3, §3.4
Operational Planning & Control	Cl. 8.1	Part 3 §3.3 (Treatment), §3.6 (Roadmap)
Performance Evaluation & Internal Audit	Cl. 9.1, 9.2	Part 2 §2.7 • Part 3 §3.7–3.9
Management Review	Cl. 9.3	Part 2 §2.9 • Part 3 §3.11
Improvement & Corrective Actions	Cl. 10.1, 10.2	Part 2 §2.8 • Part 3 §3.10
Annex A Control Selection	Annex A (93 controls)	Part 2 §2.6 • Part 3 §3.4
Risk Methodology Definition	Cl. 6.1.2(a)	Part 3 §3.1
End-to-End Programme Management	Whole standard	Part 3 §3.6 Roadmap

4.2 Conclusion

This portfolio has presented a structured, evidence-based account of an ISO/IEC 27001:2022 ISMS implementation for AWTX Solutions Pty Ltd. The work covered the full lifecycle from initial scope definition and risk assessment through to internal audit, corrective-action management, and management review, with all artefacts produced to a standard suitable for external Stage 1 and Stage 2 certification audits.

The methodology applied is consistent with the Plan–Do–Check–Act cycle, the ISO/IEC 27005:2022 risk-management guidance, and the Australian regulatory landscape including the Privacy Act 1988 (Cth) and the ASD Essential Eight maturity model. The artefacts produced are internally traceable from identified risks to selected Annex A controls, treatment actions, audit findings, corrective actions, and Management Review decisions. The due-diligence gaps raised by the enterprise customer have been formally captured and assigned to the relevant ISMS artefacts, with closure dependent on completion of the open treatment actions and NCRs. Based on the evidence presented, the Lead Implementer assessed the Q1 2026 certification readiness target as achievable within the case-study timeline, conditional on the closure of all open Major NCs, the implementation of priority risk-treatment actions, and the completion of Stage 1 readiness evidence before the external audit. The case study is presented as a structured simulation of an end-to-end ISO/IEC 27001:2022 implementation; specific dates reflect the planning horizon adopted at the time of the engagement and are retained here for academic and professional-portfolio purposes. The portfolio also serves as a demonstration of the author's professional competence to prospective employers and recruiters.

CASE-STUDY TARGETS

Stage 1 audit (document review) — February 2026 • Stage 2 audit (implementation verification) — March 2026 (case-study planning horizon)

4.3 References

- Australian Cyber Security Centre (ACSC) (2023) Essential Eight Maturity Model. Canberra: Australian Signals Directorate. Available at: <https://www.cyber.gov.au/resources-business-and-government/essential-cyber-security/essential-eight> (Accessed: 15 October 2025).
- Amazon Web Services (AWS) (2024) Shared Responsibility Model. Available at: <https://aws.amazon.com/compliance/shared-responsibility-model/> (Accessed: 20 October 2025).
- British Standards Institution (BSI) (2023) ISO/IEC 27001:2022 Transition Guide. London: BSI Group.
- Calder, A. (2018) Nine Steps to Success: An ISO 27001 Implementation Overview. 3rd edn. Ely: IT Governance Publishing.
- Humphreys, E. (2016) Implementing the ISO/IEC 27001:2013 ISMS Standard. Norwood, MA: Artech House.
- International Organization for Standardization (ISO) (2022) ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva: ISO.
- International Organization for Standardization (ISO) (2022b) ISO/IEC 27005:2022 — Information security, cybersecurity and privacy protection — Guidance on managing information security risks. Geneva: ISO.
- Office of the Australian Information Commissioner (OAIC) (2024) Australian Privacy Principles Guidelines. Sydney: OAIC. Available at: <https://www.oaic.gov.au/privacy/australian-privacy-principles> (Accessed: 18 October 2025).
- Parliament of Australia (1988) Privacy Act 1988 (Cth). Canberra: Federal Register of Legislation. Available at: <https://www.legislation.gov.au/Details/C2014C00076> (Accessed: 18 October 2025).

— END OF PORTFOLIO —

Prepared by Zain Younas • ISO/IEC 27001:2022 Lead Implementer • Melbourne, Australia